

DG INTERNS HUB
CYBERSECURITY INTERSHIP

WEEK 5 – CYBER SECURITY INTERNSHIP

VAPT Tools – Practical Learning

STUDENT NAME: NEHA FULE.

EMAIL:neha.dginternshub@gmail.com.

Date of submission: 7 october2026

TASK 1 – NMAP NETWORK SCANNING

1. Objective

The objective of Task 1 is to use Nmap for basic network reconnaissance and identify available ports, services, and basic service information on the authorized test target.

2. Tool Used

Nmap (Network Mapper) – a network scanning and service discovery tool.

3. Target

Target hostname: testphp.vulnweb.com

Testing scope: Authorized lab / training target only.

4. Commands Performed

```
nmap testphp.vulnweb.com nmap -  
sS testphp.vulnweb.com nmap -sV  
testphp.vulnweb.com nmap -A  
testphp.vulnweb.com
```

5. Scan Results & Observations

The scans were used to identify reachable network services and obtain basic information about the target.

In the captured output, HTTP (80/tcp) and HTTPS (443/tcp) were shown as filtered. A filtered port means Nmap could not determine whether the port is open because packet filtering or firewall behavior prevented a clear response.

Port	Service	Observed Status
80/tcp	HTTP	filtered
443/tcp	HTTPS	filtered

6. Screenshots / Evidence

The following evidence screenshots should be inserted below in this order:

1. Screenshot 1 – Basic Nmap scan output

```
kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.8 openssl-3.6.2 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.6 nmap-libdnet-1.18
Compiled without:
Available nsock engines: epoll poll select
```

2. Screenshot 2 – Nmap service/version detection (-sV)

```
(kali@kali)-[~]
$ nmap testphp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 04:46 -0400
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0015s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 5.71 seconds
```

3. Screenshot 3 – Nmap advanced scan output (-A)

```
(kali@kali)-[~]
$ nmap -A testphp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 04:47 -0400
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0015s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: AXIS 2100 Network Camera (92%), D-Link DP-300U, DP-G310, or Hamlet HPS01UU print server (92%), HP Tru64 UNIX 5.1A (92%), Sanyo PLC-XU88 digital video projector (92%), TRENDnet TV-IP100 webcam (92%), Vantage HD7100S satellite receiver (92%), Linux 2.6.8 (90%), Asus WL-500gP wireless broadband router (89%), Cisco 1812, 3640, or 3700 router (IOS 12.4) (89%), Cisco DOCSIS cable modem termination server (IOS 12.1) (89%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.85 ms ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.33 seconds
```

```
(kali㉿kali)-[~]
$ nmap -sS testphp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 04:50 -0400
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.00074s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 4.66 seconds

(kali㉿kali)-[~]
$
```

Task 2 – Nikto Web Vulnerability Scan

1. Objective

The objective of Task 2 was to use Nikto to perform a basic web-server vulnerability scan against the authorized training target `http://testphp.vulnweb.com` and understand the scan output.

2. Command Used

```
nikto -h http://testphp.vulnweb.com
```

3. Scan Result

Nikto started successfully, but it could not establish a connection to the target on TCP port 80. Therefore, Nikto did not produce vulnerability findings in this run.

```
(kali㉿kali)-[~]
$ nikto -h http://testphp.vulnweb.com
- Nikto v2.6.0

+ [FAIL] Unable to connect to testphp.vulnweb.com:80.

(kali㉿kali)-[~]
$
```

Figure 1: Nikto scan attempt and connection failure

4. Troubleshooting Performed

- The target was checked using ping; no ICMP reply was received.
- HTTP and HTTPS connectivity were tested using curl and both attempts timed out.
- The target IP address was tested directly and also timed out.
- Kali Internet connectivity was verified successfully using Google.
- The terminal environment was checked for proxy variables; no proxy variables were configured.
- Nmap previously showed ports 80/tcp and 443/tcp as filtered.

Task 3 – Burp Suite: Intercept & Analyze HTTP Requests

1. Objective

The objective of Task 3 was to use Burp Suite as an HTTP proxy and observe requests generated by the authorized training website. The exercise focused on understanding HTTP methods, URLs, headers, query parameters, and basic request inspection.

2. Tool Used

Burp Suite Community Edition was used with the Proxy/HTTP history feature to capture and inspect browser-generated HTTP requests.

3. Captured HTTP Requests

The Burp Suite HTTP history showed multiple GET requests to the target, including the home page, login page, artists page, and categories page.

The screenshot displays the Burp Suite Community Edition v2026.3.2 interface. The top menu bar includes File, Machine, View, Input, Devices, and Help. The main toolbar shows various tools like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, and Organizer. The 'Proxy' tab is active, and the 'HTTP history' sub-tab is selected. A table of captured requests is visible, with the following data:

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes
1	http://testphp.vulnweb.com	GET	/								
3	http://testphp.vulnweb.com	GET	/login.phphttp://testphp.vulnweb.c...					HTML	php		
5	http://testphp.vulnweb.com	GET	/login.php					HTML	php		
7	http://testphp.vulnweb.com	GET	/artists.php?artist=1	✓				HTML	php		
9	http://testphp.vulnweb.com	GET	/categories.php					HTML	php		

The 'Request' tab is selected, showing the details of the first request (GET /login.php). The request is displayed in a 'Pretty' format. The 'Inspector' tab is also visible, showing the request attributes and headers. The request headers are as follows:

```
1 GET /login.phphttp://testphp.vulnweb.com/login.php HTTP/1.1
2 Host: testphp.vulnweb.com
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
6 Chrome/146.0.0.0 Safari/537.36
7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/
8 apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
9 Accept-Encoding: gzip, deflate, br
10 Connection: keep-alive
```

4. Request 1 – Login Page

The captured request used the GET method and requested the /login.php path. The request included the Host header and standard browser headers such as Accept, User-Agent, Accept-Encoding, and Connection.

The screenshot displays the Burp Suite Community Edition v2026.3.2 interface. The top menu bar includes File, Machine, View, Input, Devices, and Help. The main toolbar shows various tools like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, and Organizer. The 'Proxy' tab is active, showing the 'HTTP history' section. A table lists intercepted requests:

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes
1	http://testphp.vulnweb.com	GET	/								
3	http://testphp.vulnweb.com	GET	/login.php	http://testphp.vulnweb.c...				HTML	php		
5	http://testphp.vulnweb.com	GET	/login.php					HTML	php		
7	http://testphp.vulnweb.com	GET	/artists.php?artist=1		✓			HTML	php		
9	http://testphp.vulnweb.com	GET	/categories.php					HTML	php		

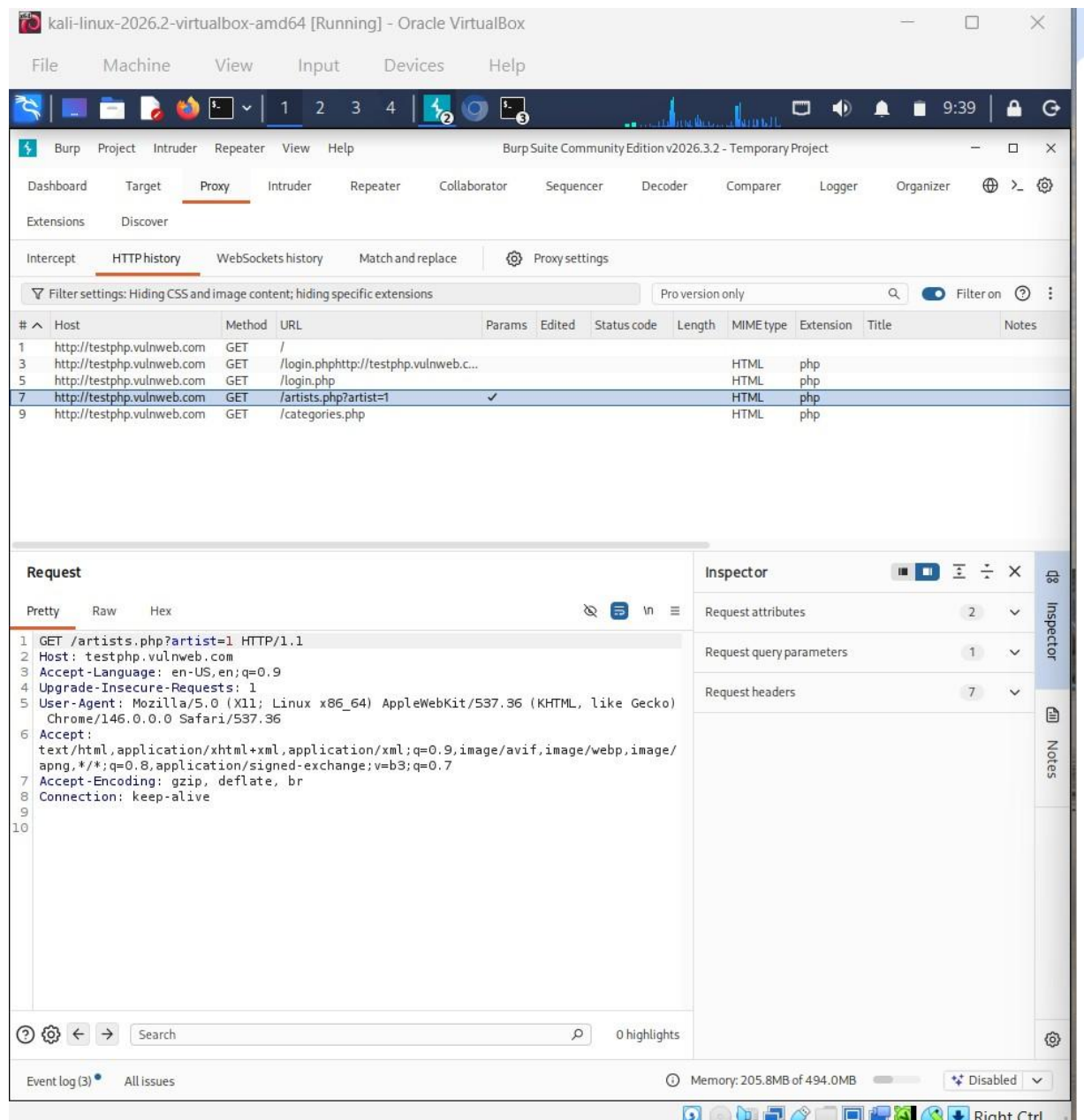
The 'Request' pane shows the details of the selected request (index 5):

```
1 GET /login.php HTTP/1.1
2 Host: testphp.vulnweb.com
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/
  apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
9
10
```

The 'Inspector' pane on the right shows the 'Request attributes' and 'Request headers' sections. The bottom status bar indicates 'Event log (3)', 'All issues', and 'Memory: 205.8MB of 494.0MB'.

5. Request 2 – Artists Page

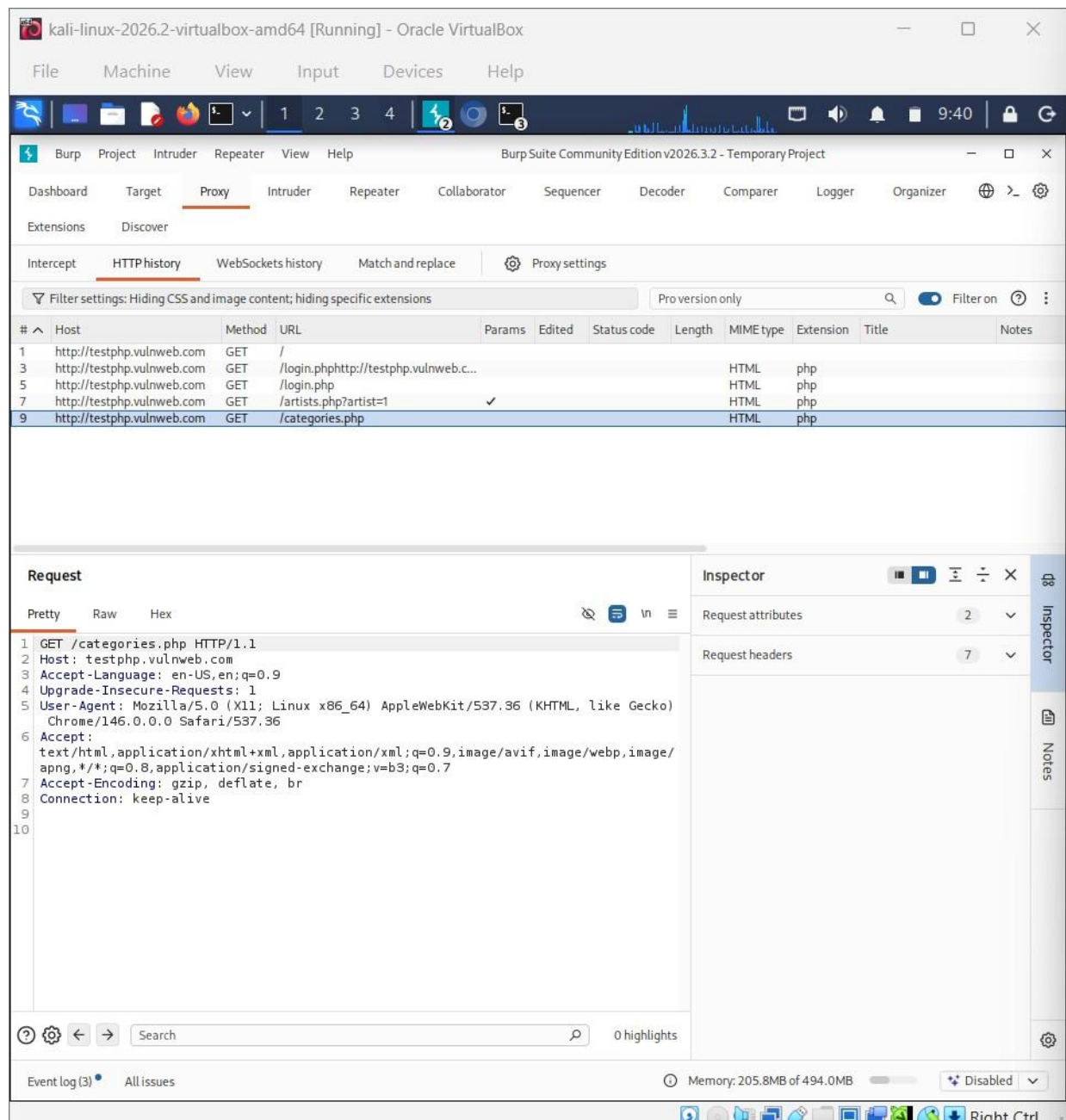
The artists request used GET and included the query parameter artist=1. This demonstrates how values can be passed to a web application through the URL query string. Burp Suite exposes this parameter for inspection.



GET /artists.php?artist=1 request and query parameter.

6. Request 3 – Categories Page

The categories request used the GET method for `/categories.php`. The request headers again showed normal browser metadata. This provides another example of a web request that can be inspected through Burp Suite.



GET /categories.php request inspected in Burp Suite.

7. Key Learning

- GET is an HTTP method commonly used to request resources from a web server.
- The Host header identifies the destination host for the request.
- User-Agent provides information about the client/browser making the request.
- Accept and Accept-Encoding describe response formats and compression supported by the client.
- Query parameters can be visible directly in a URL, such as `artist=1`.
 - Burp Suite HTTP history provides a convenient way to review captured web traffic.

Task 4 – Mini VAPT Findings

1. Objective

The objective of this mini task is to combine the learning from Nmap, Nikto and Burp Suite and document security findings observed or publicly documented for the intentionally vulnerable training application testphp.vulnweb.com.

2. Tools Used

- Nmap – network/port and service discovery.
- Nikto – web-server checks and vulnerability-oriented scanning.
- Burp Suite Community Edition – HTTP request and response interception/inspection.

3. Evidence Collected During the Practical

Nmap: the user's scan showed ports 80/tcp and 443/tcp as filtered in the current lab environment.

Nikto: the scan could not connect to testphp.vulnweb.com:80. Internet connectivity from Kali was confirmed separately, so no Nikto vulnerability results were fabricated.

Burp Suite: HTTP history captured requests including GET /login.php, GET /artists.php?artist=1 and GET /categories.php. The artists request demonstrates that the artist parameter is visible and testable through the HTTP request.

4. Finding 1 – SQL Injection Exposure

Affected area: /artists.php?artist=1

The captured Burp request contains the artist parameter. Acunetix's official security documentation uses this same testphp.vulnweb.com endpoint and documents the artist parameter as vulnerable to SQL injection.

Evidence status: Documented vulnerability of the intentionally vulnerable training target; the Burp screenshot itself proves request/parameter visibility, not exploitation.

Reference: <https://www.acunetix.com/blog/articles/sqli-part-3-the-anatomy-of-an-sql-injection-attack/>

5. Finding 2 – Cross-Site Scripting (XSS)

Affected area: testphp.vulnweb.com/listproducts.php (article parameter)

Acunetix documents a reflected XSS issue on the intentionally vulnerable testphp.vulnweb.com application and explains how the issue can be verified.

Evidence status: Publicly documented vulnerability of the training application; it was not claimed as directly reproduced from the user's screenshots.

Reference: <https://www.acunetix.com/blog/web-security-zone/how-to-verify-a-cross-site-scriptingvulnerability/>

6. Finding 3 – Additional SQL Injection / Blind SQL Injection Exposure

The Acunetix Web Vulnerability Scanner documentation for testphp.vulnweb.com lists multiple SQL injection and blind SQL injection findings across application parameters, including the artists endpoint.

Evidence status: Publicly documented vulnerability information for the intentionally vulnerable training application. It should not be presented as a fresh Nikto result because Nikto could not connect during this lab run.

Reference: <https://www.acunetix.com/resources/wvsmanual.pdf>

7. Important Limitation

The current lab environment could not reach the target with Nikto, while normal Internet access from Kali was working. Therefore, the report distinguishes between (a) findings supported by the user's own captured requests and (b) vulnerabilities documented by the target's official/public training documentation. No fabricated scan output is included.

8. Conclusion

The mini VAPT task demonstrates the workflow of discovering network services, attempting web-server scanning, and inspecting HTTP requests with Burp Suite. The Burp request to artists.php?artist=1 provides practical evidence of parameter-level testing, while the documented SQL injection and XSS issues show why input validation and output encoding are important in web application security.

9. Submission Checklist

- Task 1 – Nmap: completed with screenshots.
- Task 2 – Nikto: attempted; connection failure documented. Do not claim successful Nikto findings.
- Task 3 – Burp Suite: completed with captured HTTP history/request screenshots.
- Task 4 – Mini VAPT findings: report prepared with evidence limitations clearly stated.
- Next: combine Tasks 1–4 into the final 8–10 page report and prepare the 5–8 slide PPT.
- Next: upload the final report/screenshots/PPT to GitHub if required by the internship.
- Next: complete the required LinkedIn post and submit the final form.